Introducción a Pentest 2
Tipos de Pentesting 3
Operaciones del Pentester 4
Penetration Test 4
Fases y escenarios del hacking. 6
Fases del hacking 6
1. Definición de las normas y límites. 6
2. Recolección de la información (conocido como gathering). 7
3. Análisis de las vulnerabilidades. 7
4. Explotación de las vulnerabilidades. 7
5. Generador de los informes. 8
Modalidades de hacking 9
Vectores de ataque: ofensiva. 10
Políticas de seguridad: defensa. 11
POLITICA DE SEGURIDAD: 12
Recopilación de Información (Gathering) 13
Métodos de acceso: 14
Herramientas de escáner 14
Contramedidas 15
Seguridad en dispositivos móviles 16
Vectores de ataque 16
Plataformas móviles 16
Android 17
iOS 18
Las ocho herramientas de Pentesting más destacadas: 18
1.- Kali Linux 18
2.- Nessus 19
3.- Metasploit 19
4.- NMAP 19
5.- WireShark 19
6.- Zed attack proxy 19
7.- John the Ripper 20
8.- Burp Suite 20

Introducción a Pentest

Actualmente es imprescindible para cualquier pequeña, mediana o gran empresa invertir en ciberseguridad que evite, o al menos contenga, los ciberataques.

Cierto es que en los últimos años el número de ciberataques han aumentado significativamente debido a la proliferación de virus, malwares y a la creación de nuevas técnicas cada vez más sofisticadas. Por eso, todas las empresas se enfrentan a riesgos que ponen en peligro su sistema y pueden dejar expuesta información confidencial. Ya que, según estudios recientes, **no todas las organizaciones son conscientes de los riesgos a los que se enfrentan y por eso las brechas de seguridad siguen creciendo.**

Vivimos en una época de constantes cambios tecnológicos y uno de los mayores retos de la seguridad informática son precisamente estos avances. **Para evitar los ciberataques y proteger los sistemas, es clave que la ciberseguridad avance a la misma velocidad que lo hacen las nuevas tecnologías** y aquí es donde entra en juego el pentesting y el pentester.

¿Qué es el Pentesting y en qué consiste el trabajo del Pentester?



Debido a de los fraudes y robos de información sufridos por numerosas empresas, surge la práctica del Pentesting, que es una de las técnicas más novedosas en cuanto a lo que a Seguridad Informática se refiere.

El Pentesting es una abreviatura formada por dos palabras **"penetration" y "testing"** y es una práctica/técnica que consiste en atacar diferentes entornos o sistemas con la finalidad de encontrar y prevenir posibles fallos en el mismo.

El Pentesting o también llamado *test de penetración* está diseñado para determinar el alcance de los fallos de seguridad de un sistema**.** Asimismo, es una de las prácticas más demandadas actualmente ya que gracias a estos test, una empresa puede llegar a saber a qué peligros está expuesta y cuál es el nivel de eficiencia de sus defensas. Por eso, el "Pentester" o Auditor de ciberseguridad es una de las profesiones más demandas dentro del mundo de la Seguridad Informática, lo que los convierte en uno de los profesionales más solicitados del momento.

El Pentesting o también llamado test de penetración está diseñado para determinar el alcance de los fallos de seguridad de un sistema.

Tipos de Pentesting

Existen varios tipos de Pentesting que se clasifican según el tipo de información que se tenga a la hora de realizar los test:



Pentesting de caja blanca "White Box"

En este caso, el Pentester o Auditor conoce todos los datos sobre el sistema: Estructura, contraseñas, IPs, firewalls… Y suele formar parte del equipo técnico de la empresa**. Es el más completo y forma parte de un análisis integral de la estructura**. Gracias a toda esta información preliminar es relativamente fácil saber qué puede ser modificado o mejorado dentro de la arquitectura del sistema.

Pentesting de caja negra "Black Box"

Es el tipo de pentesting más "*real*" ya que, el Pentester no tiene apenas datos sobre la organización y actúa como un ciberdelincuente más. Por eso, como si

fuera una prueba "*a ciegas*" se debe descubrir las vulnerabilidades y amenazas en la estructura de la red.

Pentesting de caja gris "Grey Box"

Puede definirse como la mezcla de los dos anteriores, el auditor posee cierta información a la hora de realizar el test, la suficiente para no partir de cero. Es el tipo de pentest más recomendado ya que se necesitará tiempo y medios para poder realizar este test de penetración en su totalidad.

Operaciones del Pentester

El trabajo que realiza un Pentester consiste en seguir varios procesos o pasos determinados que garanticen un buen examen y que pueda realizar así todas las averiguaciones posibles sobre fallos o vulnerabilidades en el sistema, entre los que se encuentra:

Determinar Auditoría

En esta fase el Pentester debe evaluar con qué datos cuenta y qué tipo de Pentesting va a realizar. Normalmente el cliente determina el tipo de información que puede ofrecer al analista y tipo de test que quiere que se realice en el sistema.

Recogida de información

El Pentester debe realizar varias pruebas para analizar las vulnerabilidades, fugas de información .... Utilizará varias herramientas y valorará aspectos clave como la manera de proceder de los empleados o el entorno.

Acceso al sistema

Después de recabar la información y analizar de qué manera se va a actuar, se organizan los ataques y se mantiene el acceso al objetivo a atacar.

Elaboración del informe

En el informe deben aparecer el alcance e impacto de los fallos de seguridad atacados, así como una recomendación para poder minimizarlos o suprimirlos.

Penetration Test

Es una técnica o procedimiento diseñado para probar todas las posibles vulnerabilidades existentes en un sistema, que permitan evitar los controles de seguridad y ganar acceso a recursos o información crítica.



Su objetivo es medir la capacidad de las medidas defensivas de una organización frente a posibles ataques, descubriendo las debilidades de su entorno.

Un “Penetration Test” emula los mismos métodos que emplearía un posible atacante.

El tipo de “Penetration Test” depende de la organización, en particular de sus objetivos de seguridad.

En su accionar se pueden evaluar:

✓ Puertos abiertos

✓ Servicios disponibles

✓ Web Servers

✓ DNS Servers

✓ Mail Servers

✓ Configuraciones de Routers

✓ Configuraciones de Firewalls

✓ Vulnerabilidades de OS y estaciones de trabajo

✓ Acceso a información clasificada

✓ Accesos remotos, etc.

Se puede ejecutar en forma “Externa” o “Interna”, e incluye inicialmente un análisis de vulnerabilidades, pero a diferencia de éste, aquí se intenta explotar las vulnerabilidades encontradas.

El resultado obtenido, es un reporte proporcionado a la gerencia, que describe las vulnerabilidades identificadas y el grado de riesgo asociado, con recomendaciones de cómo solucionar el problema en forma adecuada.

Fases y escenarios del hacking.

Una vez nos hemos posicionados respecto a las posibles figuras que pueden aparecer en el área de la seguridad informática, es conveniente definir las fases de intrusión que se pueden llevar a cabo.

Existe todo un conjunto de metodologías, protocolos y actitudes que determinan los ataques y los análisis.

Primero de todo, hay que diferenciar tres grandes categorías dentro del hacking a la seguridad empresarial. Por un lado tenemos las auditorías de seguridad, que son un conjunto de protocolos y métodos que chequea una organización para concluir si se están llevando a cabo los estándares de procedimientos y políticas de seguridad. Por otro lado, tenemos las evaluaciones de vulnerabilidades, que se focalizan en descubrir las vulnerabilidades en los sistemas de información pero no determinan si estas vulnerabilidades pueden ser explotadas ni de cuantos daños puede causar a la empresa en el caso de que ocurriera. Por último, tenemos el test de penetración (de aquí la palabra pentesting o pentest) que es un conjunto metódico y escrupuloso que engloba las dos otras categorías; auditorias de seguridad y evaluaciones de vulnerabilidades. También intenta demostrar si dichas flaquezas del sistema pueden ser explotadas y el alcance de daños que pueda tener en la empresa, junto con una propuesta de mitigación y/o solución técnica. En este documento nos situaremos siempre desde el punto de vista del pentester y del cracker para poder realizar las pruebas.

Hay que decir que estas pruebas se realizan siempre en entornos controlados que no ponen en peligro la integridad de la información ni de la infraestructura auditada. Además, no solo se necesitan conocimientos de informática avanzados para poder llevarlos a cabo, hacen falta actitudes como el sentido común, la perspicacia y la experiencia en conjunto con la metodología y orden adecuados.

Fases del hacking

En general, las fases de un test de intrusión, desde el punto de vista de un *white hat* son las siguientes:

1. Definición de las normas y límites.

En esta primera, el auditor debe ponerse de acuerdo con la empresa auditada para establecer los parámetros y límites del pentest. Estas normas legalizarán muchas de las prácticas que el auditor llevará a cabo y que de otra forma serían ilegales, como por ejemplo acceder a información personal o realizar ingeniería inversa o social al sistema y sus usuarios. Es muy importante detallar hasta donde se está dispuesto a llegar y a qué objetivos se quiere llegar con la finalidad de salvaguardar la privacidad y no violar la ley en ningún caso. Son *las reglas del juego*.

2. Recolección de la información (conocido como gathering).

Una vez establecida la primera fase, empieza labor de recogida de información. En esta fase, el auditor deberá reunir toda la información posible acerca de los sistemas y las redes, el software y el hardware, metadatos, configuraciones, versiones de sistemas operativos, información en internet, redes sociales, etc. En este punto se realizan técnicas de fingerprinting, footprinting, google hacking, etc. Es tremendamente importante ser escrupuloso en esta fase dado que determinará el éxito o fracaso del test de intrusión, pudiendo dar falsos positivos o conclusiones inválidas. Cuanto más se sepa en este punto, mejor se podrá realizar una estrategia adecuada para la empresa. Existen casos en que la empresa facilita información, pero eso lo explicaremos más adelante.

3. Análisis de las vulnerabilidades.

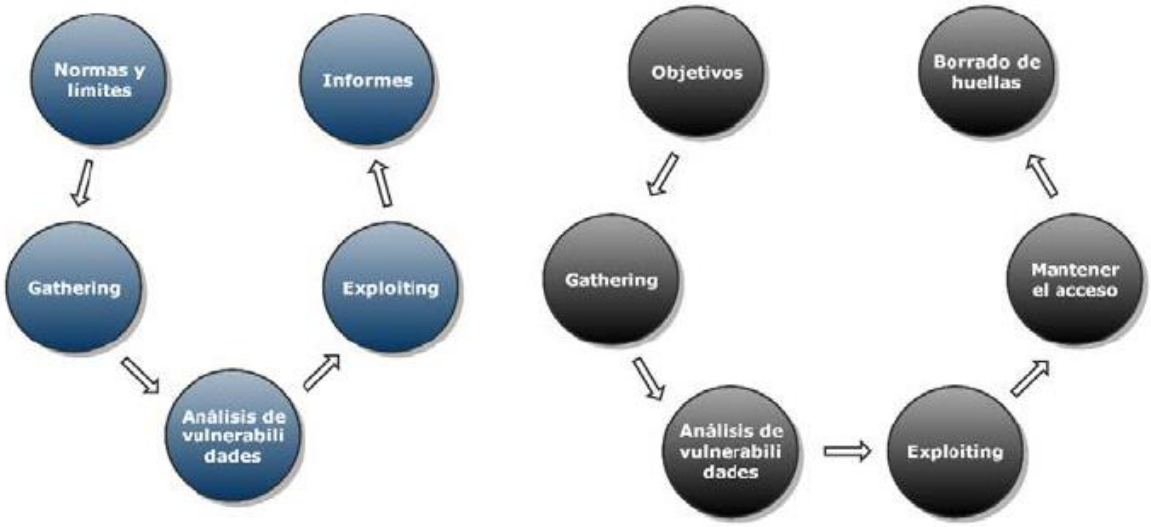
Una vez se sabe todo lo posible de los sistemas y redes, se hace un análisis exhaustivo en busca de posibles vulnerabilidades o defectos susceptibles de ser explotados. Aquí entran en juego herramientas creadas para dichas tareas (que explicaremos en los siguientes puntos) junto con la experiencia y astucia del auditor. Es evidente que pueden existir infinidad de combinaciones válidas para llegar a vulnerar un sistema, pero dependerá de la combinación de dichos factores tener más o menos éxito.

4. Explotación de las vulnerabilidades.

Esta es la fase más intrusiva y donde queda patente la realidad de las vulnerabilidades del sistema. Mediante herramientas como metasploit, se utilizan exploits para aprovechar las debilidades encontradas. El auditor deberá tener sumo cuidado al lanzar dichos exploits dado que es fácil perder el control de éstos y sobrepasar los límites descritos en la primera fase. También es común darse cuenta de que en la fase 2 y 3 quedaron puntos sin aclarar o sin descubrir. También, por ejemplo mediante técnicas de pivoteo4, será común hacerse con el control de buena parte de la red, por lo tanto nunca se deberán perder de vista los documentos de la fase 1.

5. Generador de los informes.

Por último, el pentester deberá realizar unos documentos que describan las conclusiones que todo el trabajo ha abocado. En cada fase anterior excepto la primera, se deberán ir documentando las acciones llevadas a cabo con tal de no dejarse nada en el tintero. Aquí se deberán incluir las medidas de mitigación que el auditor considere oportunas para intentar detener los posibles ataques descontrolados. También se incluirán los posibles efectos y alcances de los ataques en el caso de que se produjeran. Dado que los informes serán detallados y los receptores de éstos no deben ni tienen por qué tener conocimientos informáticos avanzados, estos se dividirán en dos: los informes técnicos y los informes ejecutivos. Los primeros contendrán los detalles técnicos y medidas precisas de mitigación de las vulnerabilidades encontradas, así como los resultados de las explotaciones de estas. En los segundos, el nivel de detalles será muy inferior, dando a entender claramente las deficiencias que ocurren así como las recomendaciones generales que el auditor propone.



Nos podemos preguntar ahora, ¿un black o grey hat no realizará estos pasos no? Pues la verdad es que los realizará exceptuando la fase 1 y 5.

La fase de definición de las normas y límites pasará a ser la fase de objetivos. Aquí el hacker definirá que quiere obtener y hasta dónde quiere llegar. Por ejemplo, si lo que quiere es hacerse con una base de datos de un servicio web para luego venderla a terceros, no le interesará destrozar todo lo que encuentre, sino ser cuidadoso para obtener toda la información posible sin corromper la información.



Por otro lado, la fase de generación de informes, se elimina, y se divide en dos, permanencia del acceso y el borrado de huellas. En la primera el intruso deberá permanecer en el sistema/red todo el tiempo que le sea posible sin ser detectado. En esta fase instalará backdoors y creará usuarios con altos privilegios, entre otras acciones, para poder perpetuar su fin con éxito. En la segunda fase, el atacante se supone que ya ha realizado las acciones o extraído la información que le interesaba al sistema, con lo que lo único que le resta es eliminar toda pista de que ha estado allí. Esto incluye borrado de logs en servers y pcs, eliminación de usuarios ocultos, entre otras técnicas. En esta última fase es donde los crackers suelen cometer más fallos y donde se define la calidad del atacante.

En este documento, debido a las limitaciones de tiempo y espacio, nos limitaremos principalmente a las fases 2, 3 y 4 de los dos puntos de vista ya que son comunes. No obstante es posible hacer algunas menciones más a las dos últimas fases del punto de vista del cracker.

Modalidades de hacking

Dependiendo de la información de la que se dispone previamente a la fase del pentest, se definirá una de las tres modalidades siguientes [3]. Es importante esta clasificación dado que la información previa es directamente proporcional a la dificultad y al tiempo de inversión del proyecto, por lo que el coste del proyecto variará sustancialmente.

White box hacking: también denominado hacking transparente, es la modalidad en la que el auditor dispone de una amplia y extensa variedad de información proporcionada directamente por la empresa a auditar. Es la modalidad que menos

recursos en costes acarreará y normalmente solo se aplica a pruebas de intrusión internas.

Black box hacking: solo se aplica a pruebas de intrusión externas, es decir, ataques desde fuera de la red. Además no se dispone de ningún dato proporcionado por la empresa que pueda suponer una cierta ventaja. Realmente es la modalidad más cercana al cracker y la más rigurosa de caras a un ataque real.

Gray box hacking: esta es la modalidad intermedia en la que el auditor dispone de algunas directrices básicas de los sistemas y de la red pero sin demasiados detalles. Por ejemplo estructura principal de la red (firewall, direcciones IP, etc.). Normalmente estas modalidades se aplican a auditorías internas dado que suele ocurrir que el auditor parte de la base de un dispositivo conectado a la red simulando un trabajador normal real.

Vectores de ataque: ofensiva.

Sabiendo ya los escenarios, los protagonistas y las posibles visiones que puede tener un pentester o cracker, toca saber los frentes por donde los ataques pueden abrir una brecha. A continuación se detalla una visión global de los principales vectores de ataques a sistemas susceptibles de ser auditados.

Principalmente tenemos **tres categorías de amenazas** [4] que abren todos los frentes siguientes (figura 3). **Amenazas en la red**	**Amenazas en los sistemas**	**Amenazas en las aplicaciones**
Ataques a firewalls e IDS	Ataques de malware	**Errores en las configuraciones**
Ataques DoS y DDoS	Footprinting	**Buffer overflow**
Envenenamientos DNS y ARP	Ataques a passwords	**SQL injection**
Hijacking y MITM	Ataques físicos	**Ataques criptográficos**
Snooping, Sniffing y eavesdropping	Backdoors y ejecución de código arbitrario	**Validación de datos de entradas incorrectos**

Facilitación de gathering	Ataques DoS	**Control y gestión de errores y excepciones incorrectos**
Keys y passwords comprometidos	Accesos desautorizados y escalada de privilegios	**Ataques sobre autorizaciones y autentificaciones**
Ataques de ingeniería social (transversal)		

Políticas de seguridad: defensa.

Por último y para redondear la visión global del hacking que necesitamos, se detallarán las principales categorías que engloban la defensa de las redes y sistemas. Normalmente existen cuatro tipos de políticas de seguridad dependiendo del grado de restricción al que se someten los trabajadores y sus sistemas [5].

Política promiscua: es una política en que los sistemas no tienen restricciones de acceso a los recursos del sistema. Una política nada recomendable.

Política permisiva: aquí existe un grado bajo de control limitando los casos más graves y evidentes de amenazas. Servicios potencialmente peligrosos son bloqueados y los sistemas deben ser actualizados con regularidad para que sean efectivos. Es una política de seguridad estándar que podríamos tener en nuestros ordenadores personales mediante nuestra configuración por defecto del sistema operativo.

Política prudente: es un grado de política de seguridad alto donde los recursos están limitados exclusivamente a las personas más imprescindibles. Todos los servicios están bloqueados excepto los imprescindibles que son accesible mediante login. Es la política de seguridad que deberían tener las empresas que trabajan con TI.

Política extrema: En este grado extremo de seguridad, la conexión a internet es nula o limitada a casos muy estrictos y cuidadosamente controlados. Puede darse en almacenes de datos donde se guardan backups masivos de grandes empresas.

Dicho esto, no nos podemos ni debemos olvidar de las políticas de seguridad física. De nada sirve establecer una política de seguridad prudente si el acceso a los sistemas es fácil físicamente. Peligros comunes como exposición al calor/frío, incendios, polvo, inundaciones, vandalismo y terrorismo, etc. pueden provocar

accesos desautorizados, robo de información, sabotaje y daños irreversibles. Aquí vuelve a aparecer el peligro de la ingeniería social que no es exclusiva de los sistemas y redes.

Por todo ello se establecen una serie de recomendaciones sobre controles de seguridad física que establecerán en mayor parte las políticas de seguridad física. Conceptos como seguridad en puertas y ventanas, cámaras CCTV, alarmas, botones de pánico, muros, guardas de seguridad, controles biométricos y dactilares, etc. son la base de la seguridad física. También forman parte un área de recepción, un área exclusiva para el servidor que no incluyan puertos externos como USB, lectores de CD/DVD, etc., desactivación por defecto de aparatos que no se utilizan frecuentemente, personal de mantenimiento informático habitual, registro de entrada y salida del edificio, control de humedad y temperatura, etc. Nos podemos encontrar también con las áreas separadas y de difícil acceso. Por ejemplo, recientemente Microsoft ha estado haciendo pruebas sobre la introducción de contenedores en el océano que contienen servidores y backups para establecer nuevas políticas de seguridad físicas.

POLITICA DE SEGURIDAD:

Debe definir los conjuntos de requisitos para la operación general de los sistemas., mediante normas, reglamentos y protocolos a seguir y debe ser conocida por todos los empleados o colaboradores.

Se deben contemplar la Integridad, Disponibilidad y privacidad de la información y aplicadas a todos los sistemas y personas de una organización.

Se debe definir que se desea proteger y el porque.

Debe ser atemporal, sin afectar eficacia y eficiencia

Adecuarse a necesidades y recursos reales de una empresa.

Se definen estrategias y criterios generales a adoptar según funciones y actividades.

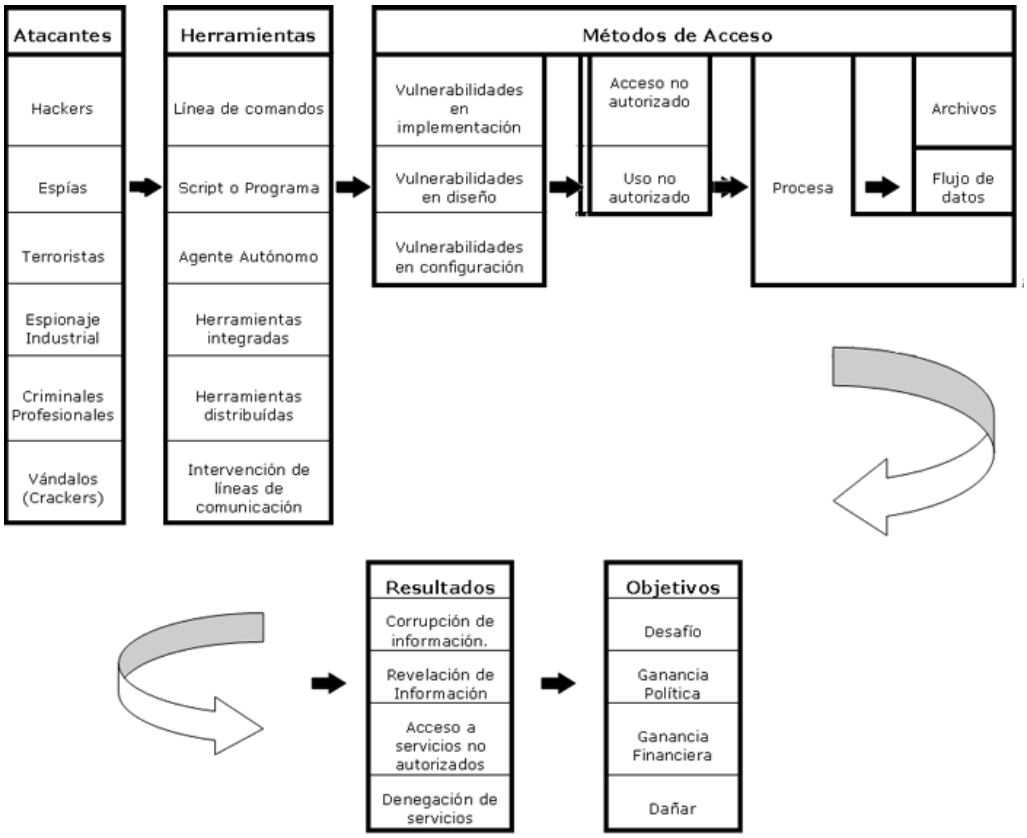
Ejemplo de documentos incluidos en Política de Seguridad:

GESTION DE CONTRASEÑAS / GESTION DE USUARIOS / GESTION DE EQUIPOS EN RED / APLICAR ISO 27001 a la empresa como guía para garantizar la Seguridad

Recopilación de Información (Gathering)

Información de sistemas	Información de redes	Información de la organización
Nombres y pass. de usuarios/grupos	DNS, IDN, IP's, etc.	Detalles de empleados
Tablas de erutación	Bloques de red	La web de la organización
Información SNMP	Webs privadas/publicas	Comentarios en código fuente
Banners del sistema	Servicios activos	Directorios de compañía
Tipo de acceso remoto a los sistemas	ACM y ACL's	Políticas de seguridad
Nombres de sistemas	Puntos VPN	Direcciones físicas
Información de banners	Números telefónicos	Detalles de localización
Versiones de sistemas operativos	Sistemas de autentificación	Links server-organización
Metadatos en general	Protocolos de red	Noticias y prensa
Software y sus versiones	Versiones de firmwares	Trasfondo de la organización

Métodos de acceso:



Herramientas de escáner

Nmap+NSE (Nmap + nmap scripting Engine): De nuevo el todopoderoso Nmap se ve reforzado con un motor de ejecución de scripts con los cuales realiza descubrimientos de red, detección de vulnerabilidades, detección de versiones más sofisticadas, detecta backdoors e incluso explota dichas vulnerabilidades. Es una de las herramientas más potentes en muchos campos [1].

OpenVAS (Vulnerability Assessment System): como su nombre indica, es un analizador de vulnerabilidades de código abierto, basado en Nessus. Está incluido en Kali 2.0 [7]

Nessus: Es otro peso pesado en el software de escáner de vulnerabilidades. Incluye perfiles agresivos que puede combinar scritps experimentales, probar servicios basados en SSL, etc. Se puede combinar también con Nikto para potenciar sus resultados [5].

Burp Suite: esta herramienta, es otra de las más completas y ya ha sido utiliza en el proceso anterior de gathering. Dispone de muchos recursos como los Spiders, y ofrece un 'todo en uno' para tener con resultados compactos [6].

Hay varios softwares interesantes adjuntos en el Anexo.

Existen 5 tipos generales de vulnerabilidades [14]. En la figura 5.1 podemos ver un cuadro de algunos de los posibles tipos de vulnerabilidades que nos podemos encontrar al realizar los escáneres.



Figura 5.1 – Esquema de los tipos de vulnerabilidades más encontradas.

Las casusas típicas de estas vulnerabilidades también se pueden catalogar en varios tipos:

Diseño: implican debilidades de diseño de protocolos de red y políticas de seguridad deficientes o nulas.

Implementación: Incluyen existencia de backdoors, errores de programación y descuido de los fabricantes.

Uso: Esta causa implican malas configuraciones, desconocimiento/ falta de sensibilización con los temas de seguridad informática, poca disponibilidad de las herramientas de seguridad y limitaciones gubernamentales de tecnologías efectivas en pro a la seguridad de las TIC.

0Day: Son aquellas que se conoce su existencia pero aún no se ha establecido ninguna corrección por parte de la empresa o institución fabricante.

Contramedidas

A continuación, se detallan algunas de las principales recomendaciones y buenas prácticas. Las medidas son parecidas a las de hardening de redes, servidores y aplicaciones web en general:

- Realizar un hardening de los sistemas operativos y las aplicaciones de los equipos que vayamos a conectar a la red.
- Deshabilitar los servicios y puertos que no se vayan a utilizar. Por ejemplo si solo es consulta de información via HTTPs, solo necesita los puertos 80 y 443 abiertos. Se trata de minimizar y acotarlo recursos.
- Habilitar las actualizaciones automáticas de los sistemas operativos.

- Todos sabemos que hay sistemas operativos más seguros que otros, por ejemplo Windows server y Apache, por lo que es recomendable utilizar los menos susceptibles a ataques y análisis.
- Tener al día los contratos con suministradores de software/hardware para acudir a ellos en caso de aparición de un 0Day.
- Diseñar la red con DMZ, IDS, firewalls, Honeypotsetc. para evitar el escaneo indiscriminado…
- …y aplicar y configurarlos correctamente, es decir, aplicar las reglas a los firewalls indicadas para rechazar escaneos (desde fuera hacia adentro y al revés).

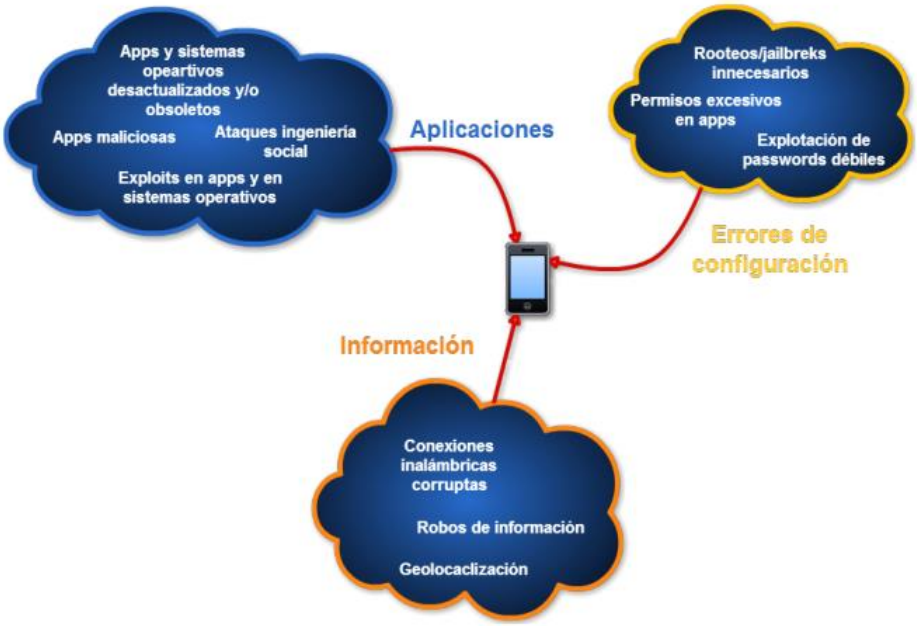
Realizar la tarea de un pentester en la propia red para intentar descubrir fallas de seguridad.

Seguridad en dispositivos móviles

Después de todo lo comentado, cabe hacer comentarios especiales para los dispositivos móviles [1, 11]. La mayoría de métodos y explicaciones dadas sieguen siendo válidas pero con la llegada de los smartphones y tabletas el abanico de posibilidades se amplía considerablemente. Sobre todo, aumentan los frentes abiertos, focos de infecciones de malware.

Vectores de ataque

Los principales vectores de ataque que nos podemos encontrar (algunos ya mencionados y comunes) son los siguientes (figura)



Plataformas móviles

Existen numerosos sistemas operativos que son utilizados por los dispositivos móviles. Android e iOS son los más usados, pero existen otros como Symbian, BlackBerry iOS, ChromeOS, Windows

Phone o Firefox OS [1] . Aquí, nos centraremos en los dos primeros dado que son los más utilizados.

Android

Sistema operativo más usado tanto en tabletas como en smartphones, propiedad de Google y basado en Linux, por lo tanto, heredero de muchos exploits descubiertos de dicho S.O. Arquitectónicamente consta de consta de una base de datos estructurada SQLite, navegador de internet integrado basado en el software libre WebKit engine, soporta multiples formatos de audio, video, imagen, etc. Si le sumamos a todo esto un rico entorno de desarrollo (debug, emulador de dispositivos, plugin para Eclipse, etc.) y una plataforma de aplicaciones online masiva, nos encontramos con un ordenador personal en el bolsillo, susceptible de ser vulnerado por la gran información sensible que poseen.

Su arquitectura a nivel interno se divide en 4 capas:

1. Aplicación: incluye las aplicaciones típicamente utilizadas por los usuarios comunes, contactos, navegador, teléfono, etc.

2. Framework de aplicación: este nivel incluye aspectos secundarios y de administración respecto del usuario, como la gestión de ventanas, manejo de notificaciones, instalación de paquetes, manejo de localizaciones, etc.

3. Librerías: El tercer nivel es transparente al usuario e incluye todas las librerías necesarias para el funcionamiento del sistema. Esto incluye por ejemplo gestión de SSL, libc, SQLite, WebKit, OpenGL, y las librerías de ejecución en tiempo real nombradas como Android RUNTIME etc. Por defecto, un usuario no tendrá nunca acceso a esta capa a no ser que sea desarrollador o haga rooteo al teléfono, que no es más que aplicar técnicas de elevación de privilegios en el propio dispositivo.

4. Linux Kernel: Aquí es la capa más profunda del sistema operativo y la más sensible. Es la base de éste ya que incluye todos los drivers de cámara, wifi, memoria flash, keypad, pantalla, batería, audio, etc.

Un atacante siempre intentará efectuar un ataque empezando por lo más simple posible (primeras capas) hasta llegar a la manipulación del kernel. Por defecto, los usuarios de estos sistemas operativos no tienen todos los permisos posibles para evitar daños y por motivos de seguridad, en caso de infección de malware. Es por eso, si un atacante logra acceder al dispositivo, muy probablemente quiera tener permisos administrativos (también llamados de super usuario, o root) y a partir de ese punto, podrá ejercer acciones a su antojo. Una acción común es modificar un sistema operativo (llamados ROMS) que incluyen funciones especiales para luego instalarlas en un dispositivo con permisos root. El proceso de root está expresamente prohibido por los fabricantes y anula las garantías en el mismo instante en que se hace, por lo que se puede considerar un hackeo del dispositivo. Existen herramientas de rooteo que permiten realizar estas acciones .

Es posible también ejercer técnicas de spoofig y de hijacking con un terminal con Android.

iOS

El caso de iOS es diferente al de Android. Mientras el primero se basa en una filosofía de código parcialmente abierto, iOS es más cerrado en ese aspecto y por defecto tiene su kernel cifrado para que no sea posible manipularlo ni editarlo. Es por ello que los investigadores y crackers han de buscar vulnerabilidades en el sistema con tal de poder instalar un kernel modificado y obtener privilegios root. Por lo tanto, romper la seguridad base del sistema operativo es una tarea compleja llamada jailbraking. Una vez descubierta la vulnerabilidad, se procede como ya se ha escrito, creando un exploit y difundiéndolo para que los programadores han sus propias versiones de iOS añadiendo funciones que la compañía no permite o que cobran por ello (liberación del móvil de una compañía, instalaciones de apps de terceros, etc.).

Herramientas Android

Algunas herramientas útiles para Android son:

Rooting: tenemos SuperOneClick, SuperBoot, One click root, o Kingo Android ROOT.

Troyanos y RAT's: ZitMo, FakeToken, TRAMP.A, Obad, o Fakedefender, AndroRAT, Dendroid. Sniffers y hijackers y spoofers:Packet Sniffer, Fing, NetX, tPacketCapture, Android PCAP, FaceNiff, DroidSHeep o Network Spoofe.

Herramientas de seguridad:

TrustGo Mobile Security, Sophos Mobile Security, DroidSheep Guard, Remote wipe y en general, la mayoría de antivirus más utilizados para los sistemas fijos, tienen su símil en plataformas móviles. Rastreo de dispositivo: son las herramientas que se dedican a tener localizado nuestro dispositivo. Algunas son: FinfMyPhone, Prey Anti-thef, Where is my Droid, iHound, AndroidLost.com.

iOS Jailbreaking : Cydia, Pangu, Redsn0w, Absinthe, evasi0n7, GeekSn0w, Sn0wbreeze o PwnageTool. Ratreo: iHound, FindMyPhone, iLocalis o GadgetTrak iOS Security.

En las últimas versiones del S.O. ya se incluyen herramientas de rastreo por defecto.

Herramientas de pentesting

Existen algunas herramientas especiales de pentesting de ámbito general (toolkits) como son zAnti, dSploit, X-Scan o Hacode.

Las ocho herramientas de Pentesting más destacadas:

Este análisis de penetración te ayuda a conocer el alcance de los fallos de seguridad y establecer medidas se seguridad para evitar las consecuencias. Estas son las utilidades que permiten salvaguardar los datos.

1.- Kali Linux

Es de las mejores del mercado. Se trata de una distribución completa de Linux especializada en la auditoría de seguridad de sistemas. Cuenta con 300 herramientas para realizar análisis de penetración, aunque están especializadas en la ofensiva. En cualquier caso se detectará cualquier fallo en el sistema en poco tiempo y sin esfuerzo. Además, es el sistema operativo predeterminado que utiliza la mayoría de profesionales, por lo que no hay que subestimarlo.

2.- Nessus

Se trata de una aplicación centrada en identificar vulnerabilidades en los servicios. Cuenta con una amplia base de datos y es muy sencilla de utilizar, lo que la hace ideal para iniciarse en el mundo de los análisis de penetración. Algo que se debe en gran parte a la sencillez de su interfaz, la cual resulta sumamente intuitiva. Es posible probar miles de vulnerabilidades sin establecer parámetro alguno, lo que mejora aún más la facilidad de uso de esta herramienta.

3.- Metasploit

Entra en juego cuando se ha descubierto las vulnerabilidades del sistema, pero no se conoce cual es el alcance de estas o el daño que pueden llegar a causarte. Así mismo también permite saber que contramedidas son las acertadas para detener una posible amenaza. Esta herramienta cuenta con una base de exploits de diferentes vulnerabilidades, lo que permite conocer la gravedad del error. Sin dudas de las más útiles que hay.

4.- NMAP

Es una herramienta de las más utilizadas y mas veteranas. Es capaz de escanear los puertos de un servidor, conocer cuales están abiertos y que vulnerabilidades representan. Juega un rol importante a la hora de realizar un análisis de reconocimiento. Los especialistas en hacking ético la utilizan con regularidad para conocer la seguridad pública de una compañía y avisar incidencias que puedan existir.

5.- WireShark

Permite comprender el estado del tráfico de la red de una empresa. Analiza cientos de protocolos, es capaz de capturar el tráfico en tiempo real y conocer lo que ocurre con gran detalle. Es utilizado para controlar las conexiones TCP/IP y en manos de un buen analista es realmente eficaz, ya que este podrá determinar desde donde llegan las amenazas y actuar en consecuencia con rapidez.

6.- Zed attack proxy

Esta herramienta actúa entre la página web y el navegador utilizado. Consigue captar todo el tráfico, inspeccionarlo y modificarlo para reconocer los fallos de la web. Es sencillo de utilizar gratuito y su código es abierto, por lo que puede modificarse para mejorarlo o añadirle nuevas funcionalidades. Es otra aplicación para principiantes que revela las vulnerabilidades relacionadas con el tráfico.

7.- John the Ripper

Esta especializado en descifrar contraseñas sin conexión. Lo que permite conocer la fiabilidad de las contraseñas creadas. Puede actuar de forma bruta recurriendo a la capacidad de procesamiento de un PC hasta encontrar la contraseña. Lo cual puede llevarte literalmente millones de años, o alternar los signos de la base de datos de posibles contraseñas que contiene. Además, es capaz de desencriptar archivos, lo cual otorga una nueva dimensión a este software de código libre.

8.- Burp Suite

Este es uno de los analizadores más completos del mercado. Se centra en el análisis de vulnerabilidades de páginas web, lo que lo hace valioso. Lanza toda una serie de ataques contra la web seleccionada y en poco tiempo determina que falla. Es una herramienta utilizada solo por profesionales, pero ofrece unos resultados fuera de toda duda. La contrapartida de esta aplicación es su costo (3000 euros por año, la versión Enterprise).